



Student Name: Chandler Matere Simiyu

Admission Number: BSCCS/2024/58571

Course Name: Bachelor of Science in Computer Science

Unit Code: BIT4139

Unit Name: Ethical Hacking and Counter Measures

Lecturer: Mr. Nyoro Michael

Year III, Semester VI

STEP 1: INFORMATION GATHERING AND RECONNAISSANCE.....	3
1.1: Target IP Address Identification.....	3
Figure 1: DNS Resolution and IP Identification for kenya-airways.com.....	3
1.2: Domain Registrar and Public Records.....	4
Figure 2: WHOIS Domain Information and Registrar Records.....	4
1.3: Subdomain and Infrastructure Discovery.....	5
Figure 3: Maltego Infrastructure and Subdomain Mapping.....	5
1.4 Employee Email Pattern Enumeration.....	6
Figure 4: Corporate Email Pattern Discovery via Maltego.....	6
1.5: Web Technologies Profile.....	7
Figure 5: Web Application Technology Stack Profiling via builtwith.com.....	7
STEP 2: SCANNING AND ENUMERATION.....	7
2.1: External Network Path Mapping.....	8
Figure 6: External ICMP Traceroute to scanme.nmap.org.....	8
2.2: Internal Network Footprinting.....	9
Figure 7: Local Subnet MAC Address Enumeration.....	9
2.3: Internal Port and Service Enumeration.....	10
Figure 8: Comprehensive Nmap Port and Service Scan of Local Gateway.....	10
Step 3: Gaining Access.....	10
3.1 Tables with vulnerabilities, exploitation, impact and mitigation.....	11
Figure 9: DVWA SQL Injection Module - Validating Legitimate User Input.....	11
Step 4: Creativity Application & Advanced Mitigation.....	12
Figure 10: Secure Application-Layer Mitigation Using PHP Data Objects (PDO).....	12

STEP 1: INFORMATION GATHERING AND RECONNAISSANCE

Target Organization: Kenya Airways (kenya-airways.com)

1.1: Target IP Address Identification

```
C:\Users\chand>nslookup kenya-airways.com 8.8.8.8
Server:  dns.google
Address:  8.8.8.8

Non-authoritative answer:
Name:     kenya-airways.com
Address:  217.114.94.2

C:\Users\chand>
```

Figure 1: DNS Resolution and IP Identification for kenya-airways.com

1.2: Domain Registrar and Public Records

kenya-airways.com

Updated 5 days ago

Domain Information

Domain:	kenya-airways.com
Registered On:	1997-05-26
Expires On:	2031-05-25
Updated On:	2024-05-21
Status:	client transfer prohibited
Name Servers:	ns0.accesskenya.com ukns1.accesskenya.com

Registrar Information

Registrar:	TLDS L.L.C. d/b/a SRSPlus
IANA ID:	320
Abuse Email:	domain.operations@web.com
Abuse Phone:	+1.8777228662

Figure 2: WHOIS Domain Information and Registrar Records

1.3: Subdomain and Infrastructure Discovery

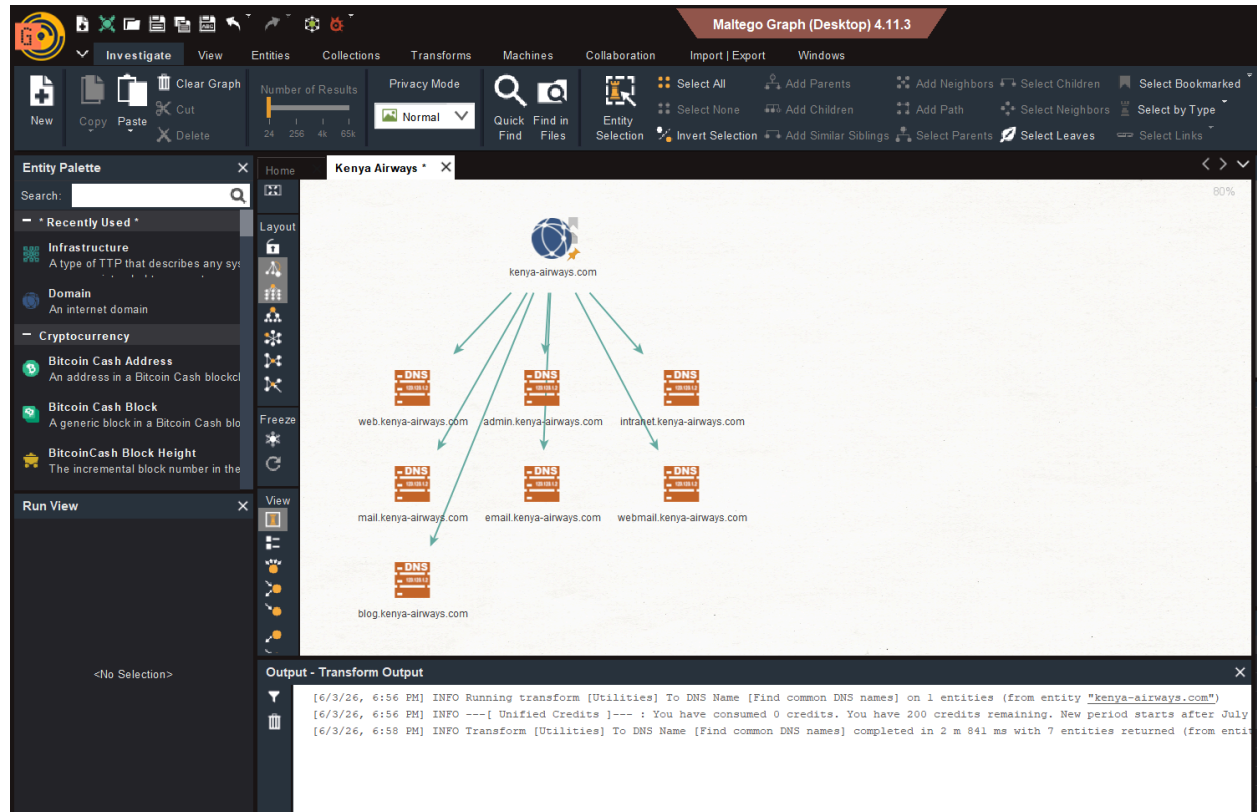


Figure 3: Maltego Infrastructure and Subdomain Mapping

1.4 Employee Email Pattern Enumeration

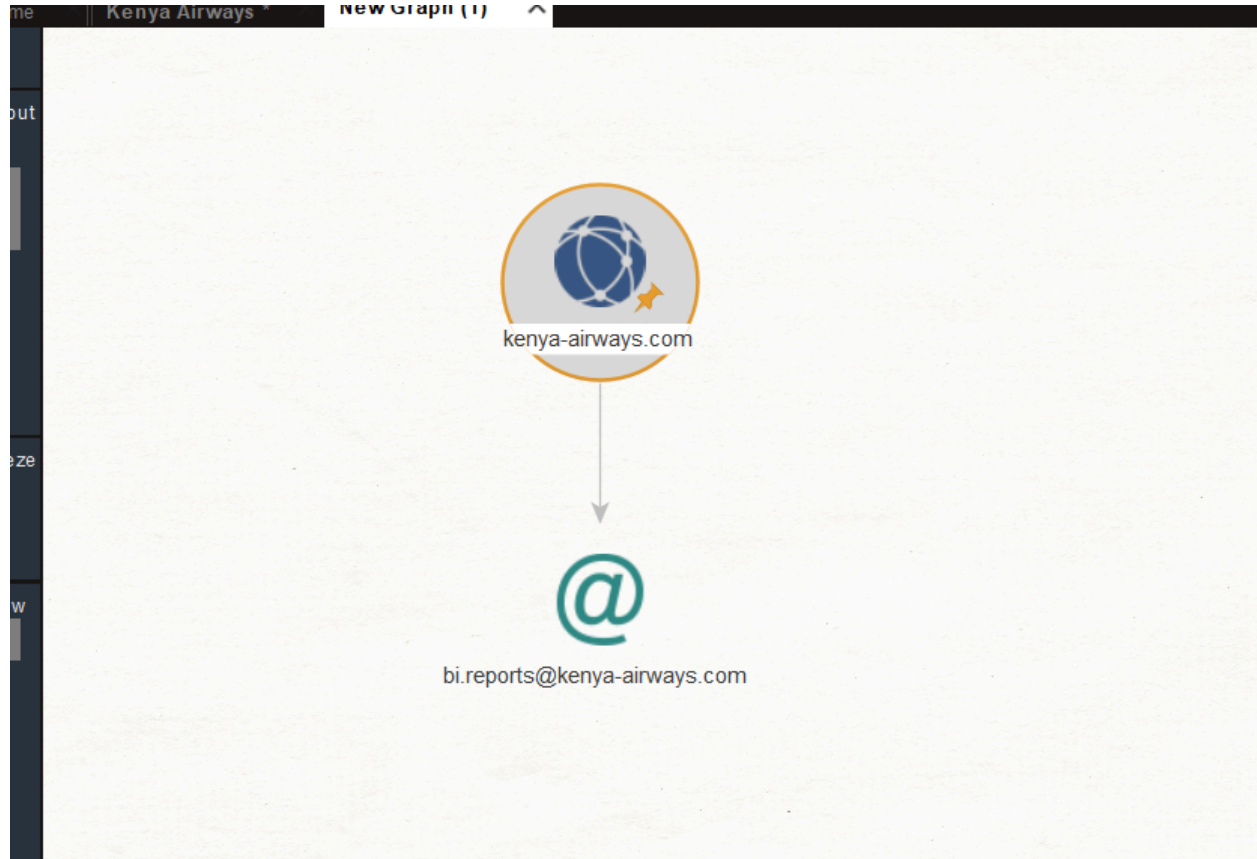


Figure 4: Corporate Email Pattern Discovery via Maltego

1.5: Web Technologies Profile

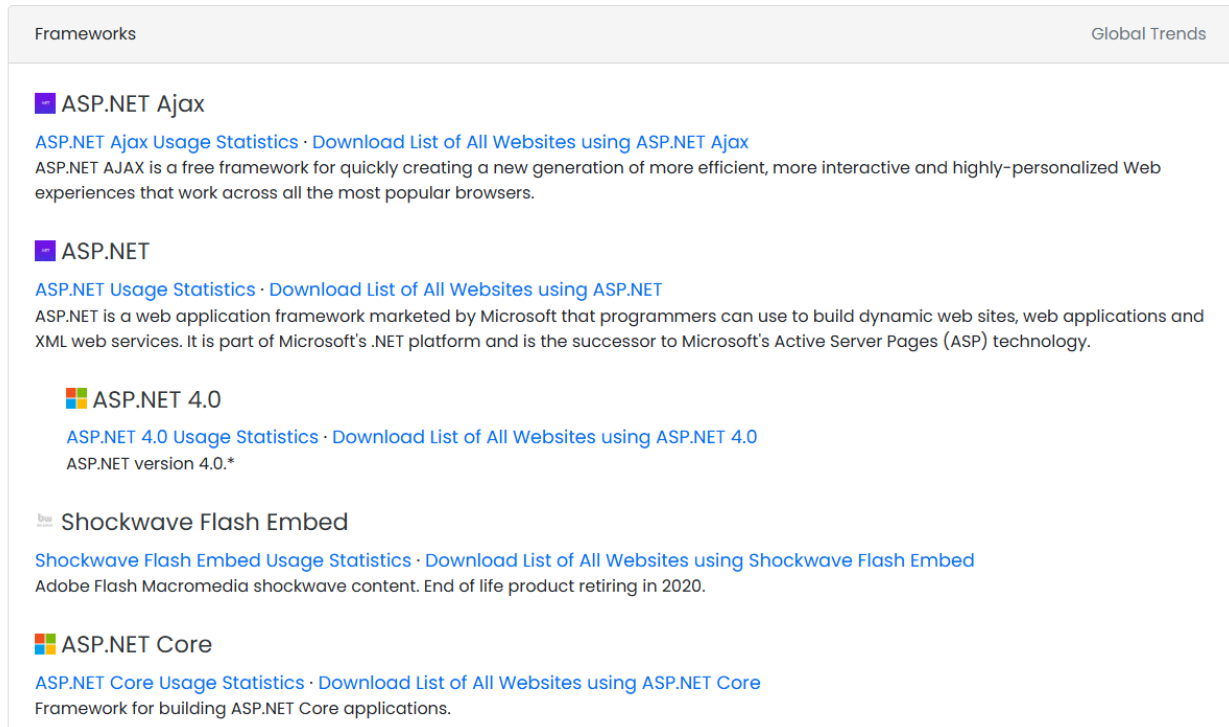


Figure 5: Web Application Technology Stack Profiling via builtwith.com

STEP 2: SCANNING AND ENUMERATION

Targets: scanme.nmap.org (External) and 19.168.100.1 (Internal Gateway)

2.1: External Network Path Mapping

```
C:\WINDOWS\system32\cmd. x + v
Microsoft Windows [Version 10.0.26200.8457]
(c) Microsoft Corporation. All rights reserved.

C:\Users\chand>tracert kenya-airways.com

Tracing route to kenya-airways.com [217.114.94.2]
over a maximum of 30 hops:

 1    2 ms    3 ms    2 ms  172.20.21.22
 2    9 ms    2 ms    2 ms  197.136.58.1
 3   18 ms    8 ms    7 ms  kl-dfl.pu-mku-main.n.kenet.or.ke [41.204.180.65]
 4    3 ms    4 ms    6 ms  l.sameer-usiu.n.kenet.or.ke [197.137.248.170]
 5  140 ms  140 ms  142 ms  197.136.176.57
 6  140 ms  155 ms  140 ms  lt-11-3-0.3-amsterdam-ua-ams11-ams1-01.ubuntunet.net [196.32.210.75]
 7  145 ms  141 ms  182 ms  80.249.210.118
 8    *    143 ms  150 ms  141.101.65.1
 9  141 ms  143 ms  143 ms  141.101.65.103
10  145 ms  141 ms  147 ms  217.114.94.2

Trace complete.

C:\Users\chand>
```

Figure 6: External ICMP Traceroute to scanme.nmap.org

2.2: Internal Network Footprinting

```
C:\Users\chand>arp -a

Interface: 172.20.75.163 --- 0x12
    Internet Address      Physical Address      Type
    172.20.21.22          00-09-0f-09-00-02    dynamic
    172.20.33.37          28-d0-ea-24-53-d3    dynamic
    172.20.33.44          16-79-1d-6e-f9-57    dynamic
    172.20.40.247         90-61-ae-ab-17-74    dynamic
    172.20.43.95          70-cf-49-ca-ec-ca    dynamic
    172.20.60.250         d2-a7-0e-57-75-1c    dynamic
    172.20.67.88          7e-a0-61-6f-06-92    dynamic
    172.20.73.179         7c-4d-8f-a9-58-52    dynamic
    172.20.78.5           f8-59-71-c6-8a-8b    dynamic
    172.20.78.34          10-b6-76-51-e4-6f    dynamic
    172.20.92.24          74-56-3c-ae-e8-5a    dynamic
    172.20.94.224         f8-89-d2-8a-65-e3    dynamic
    172.20.100.123        6e-ac-2a-50-65-c7    dynamic
    172.20.109.57         48-2a-e3-3c-47-2c    dynamic
    172.20.255.255        ff-ff-ff-ff-ff-ff    static
    224.0.0.22            01-00-5e-00-00-16    static
    224.0.0.251           01-00-5e-00-00-fb    static
    224.0.0.252           01-00-5e-00-00-fc    static
    239.255.255.250       01-00-5e-7f-ff-fa    static

Interface: 192.168.56.1 --- 0x13
    Internet Address      Physical Address      Type
    192.168.56.255        ff-ff-ff-ff-ff-ff    static
    224.0.0.22            01-00-5e-00-00-16    static
    224.0.0.251           01-00-5e-00-00-fb    static
    224.0.0.252           01-00-5e-00-00-fc    static
    239.255.255.250       01-00-5e-7f-ff-fa    static

C:\Users\chand>
```

Figure 7: Local Subnet MAC Address Enumeration

2.3: Internal Port and Service Enumeration

```
c:\Users\chand>nmap -sV --script vuln 192.168.100.1
Starting Nmap 7.90 ( https://nmap.org ) at 2026-05-16 17:12 +0300
Nmap scan report for 192.168.100.1
Host is up (0.0042s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
21/tcp    filtered  ftp
22/tcp    filtered  ssh
23/tcp    filtered  telnet
53/tcp    open      domain       (generic dns response: no error)
|_ fingerprint-strings:
|   DNS-SD-TCP:
|     _services
|       _dns-sd
|       _udp
|       local
|_   root-servers
80/tcp    filtered  http
443/tcp   open      ssl/https?
|_ http-enum:
|   /blog/: Blog
|   /weblog/: Blog
|   /weblogs/: Blog
|   /wordpress/: Blog
|   /wiki/: Wiki
|_  /mediawiki/: Wiki
|_ http-fileupload-exploiter:
|   Couldn't find a file-type field.
|_ Couldn't find a file-type field.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-sql-injection: ERROR: Script execution failed (use -d to debug)
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
8022/tcp  filtered  oa-system
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
```

[illegible]

Figure 8: Comprehensive Nmap Port and Service Scan of Local Gateway

Step 3: Gaining Access

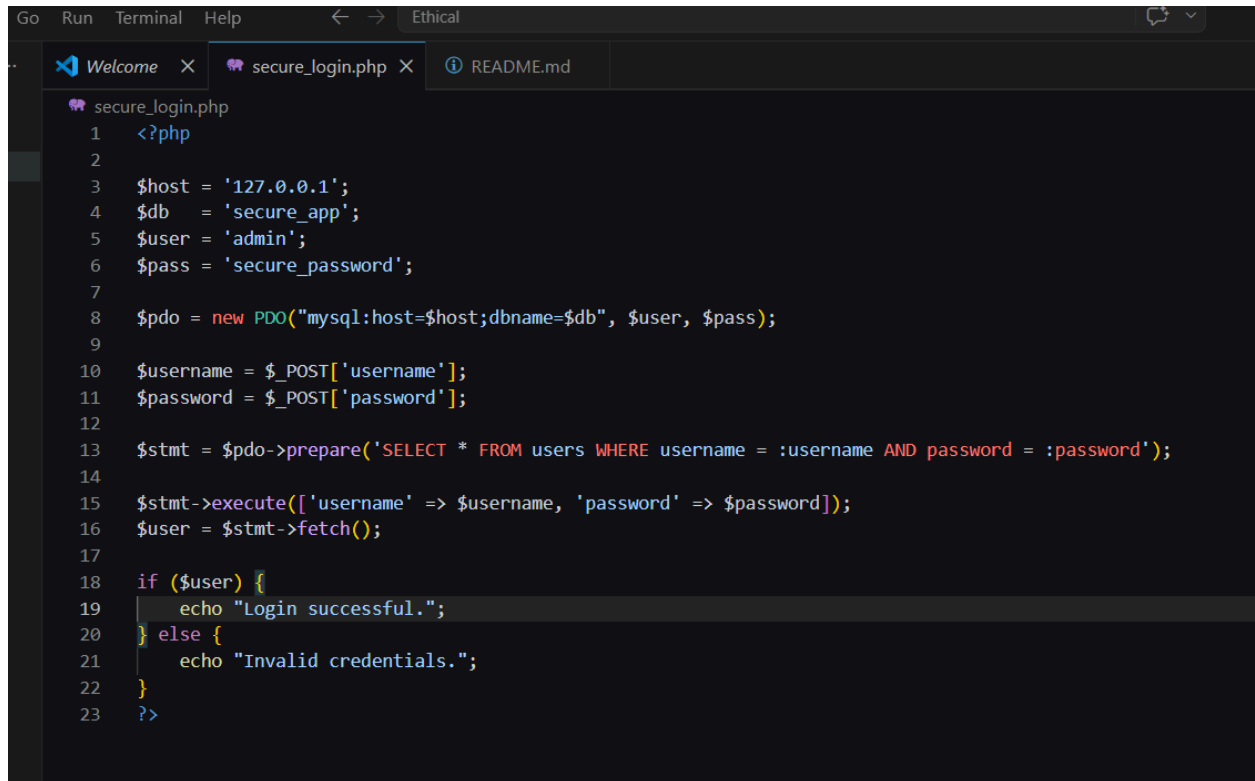
3.1 Tables with vulnerabilities, exploitation, impact and mitigation

Vulnerability	Exploitation	Impact	Mitigation
SQL Injection	'1'='1	Forces the database query to evaluate as "True", allowing for authentication bypass or unauthorisation access to sensitive database records.	Parameterized Queries

The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. At the top is the DVWA logo. On the left is a sidebar with navigation links: Home, Instructions, Setup, Brute Force, Command Execution, CSRF, File Inclusion, SQL Injection (highlighted in green), SQL Injection (Blind), Upload, XSS reflected, XSS stored, DVWA Security, PHP Info, About, and Logout. The main content area is titled "Vulnerability: SQL Injection". It contains a "User ID:" label, a text input field with the value "'1'='1'", and a "Submit" button. Below this is a "More info" section with three links: <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>, http://en.wikipedia.org/wiki/SQL_injection, and <http://www.unixwiz.net/techtips/sql-injection.html>. At the bottom left, it shows "Username: admin", "Security Level: low", and "PHPIDS: disabled". At the bottom right, there are "View Source" and "View Help" buttons.

Figure 9: DVWA SQL Injection Module - Validating Legitimate User Input

Step 4: Creativity Application & Advanced Mitigation

A screenshot of a code editor with a dark theme. The editor has tabs at the top: 'Welcome', 'secure_login.php', and 'README.md'. The 'secure_login.php' tab is active. The code is a PHP script for a secure login application. It uses PDO to connect to a MySQL database. The script sets database credentials, connects to the database, and then checks the username and password against the database. If the credentials are valid, it echoes 'Login successful.'; otherwise, it echoes 'Invalid credentials.'.

```
1  <?php
2
3  $host = '127.0.0.1';
4  $db   = 'secure_app';
5  $user = 'admin';
6  $pass = 'secure_password';
7
8  $pdo = new PDO("mysql:host=$host;dbname=$db", $user, $pass);
9
10 $username = $_POST['username'];
11 $password = $_POST['password'];
12
13 $stmt = $pdo->prepare('SELECT * FROM users WHERE username = :username AND password = :password');
14
15 $stmt->execute(['username' => $username, 'password' => $password]);
16 $user = $stmt->fetch();
17
18 if ($user) {
19     echo "Login successful.";
20 } else {
21     echo "Invalid credentials.";
22 }
23 ?>
```

Figure 10: Secure Application-Layer Mitigation Using PHP Data Objects (PDO)